

Web-Security und Intrusion Prevention

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 6 Cross Site Request Forgery

Lernziele: Broken Access Schwachstellen aufzeigen und verhindern

Abgabetermin wird bekannt gegeben

Aufgabe 1: Verstehen der Webanwendung

Die Anwendung besteht aus zwei in Python geschriebenen Anwendungen: Das bereits von Ihnen bekannte Gästebuch und eine Online-Banking-Anwendung.

- Starten Sie die Anwendung mit `docker compose build && docker compose up`.
- Öffnen Sie das Gästebuch unter <http://127.0.0.1:5000>
- Das Passwort lautet „password123“.
- Testen Sie, ob Sie einen Eintrag machen können.
- Öffnen Sie die Banking-Seite unter <http://127.0.0.1:5001>. Existierende Benutzer und Passwörter lauten: Alice (alice123), Bob (bob123) und Eve (eve123).
- Loggen Sie sich mit dem Benutzername alice ein.

Aufgabe 2: Informieren Sie sich über die Online-Banking Webseite

In der Vorlesung haben Sie kennengelernt, dass Sie über CSRF Aktionen auf entfernten Webseiten ausführen können. Diese Aktionen werden im Kontext des eingeloggten Benutzers ausgeführt. Damit ein Angriff erfolgreich ist, müssen Sie verstehen, wie Sie die Webseite ausnutzen können.

- Öffnen Sie die Entwicklerkonsole in Firefox (STRG+SHIFT+i)
- Machen Sie eine kleine Überweisung von Alice an Bob, z.B. mit 10€
- Finden Sie in der Entwicklerkonsole heraus, welche Parameter notwendig sind.

Aufgabe 3: Nutzen Sie die XSS-Lücke im Gästebuch aus, um eine Überweisung zu tätigen

In der Vorlesung haben Sie kennengelernt, dass das HTML `<img>`-Tag sehr geeignet ist, um einen CSRF-Angriff zu starten: Das Laden eines Bildes ist unauffällig. Ein potentielles Opfer bemerkt den Angriff daher nicht, da der Browser kein ungewöhnliches Verhalten zeigt.

Es sollen 500€ an das Bankkonto von Eve übertragen werden

- Geben Sie an, was Sie im Gästebuch eintragen, um die Überweisung per CSRF zu tätigen
- Öffnen Sie wieder die Entwicklerkonsole und verfolgen Sie den böartigen Aufruf durch Ihr gefälschtes „Bild“. Welche SEC-FETCH-Header sendet der Browser an die Online-Banking Anwendung? Machen Sie einen Screenshot
- Könnten Sie einen CSRF-Angriff auch tätigen, wenn die Banking-Anwendung seine Parameter mit POST übertragen würde? Wie könnte ein solcher Angriff aussehen? Würde es immer noch in einem `<img>`-Tag funktionieren oder müssten Sie etwas anderes machen?

Aufgabe 4: Sichern Sie die Anwendung ab

Es existieren mehrere Möglichkeiten eine Webseite vor CSRF-Angriffen zu schützen. Eine sehr effektive Möglichkeit ist die Nutzung von CSRF-Token. Ändern Sie die Online-Banking-Anwendung so ab, dass CSRF-Tokens genutzt werden.